Mandat d’audit de sécurité réseau

Référence : MAND-3020-TP8 · **Nature** : audit en boîte blanche, à des fins pédagogiques · **Durée** : séance du TP 8.

1. Parties

Commanditaire : la direction de la PME fictive « Lab 3-020 », représentée par le formateur. **Auditeur** : l’apprenant désigné ci-dessous, agissant dans le cadre de la formation « Sécurisation des architectures réseaux ».

Nom de l’auditeur : _____

2. Objet

Évaluer le niveau de sécurité de l’architecture réseau du laboratoire de l’auditeur : cloisonnement, filtrage, services exposés, authentification, interconnexion « cloud », journalisation. Produire un rapport d’audit avec constats prouvés, cotés et assortis de recommandations.

3. Périmètre autorisé

Élément	Adresses
Réseau LAN	10.1.10.0/24
Zone serveurs (SRV)	10.1.20.0/24
DMZ	10.1.30.0/24
VPC « cloud »	10.101.1.0/24
« Internet » simulé du lab (WAN)	10.10.0.20 (pfSense), 10.10.0.30 (cloud-gw), 10.10.0.40 (ext)
Pare-feu pfSense	interfaces 10.10.0.20, 10.1.10.1, 10.1.20.1, 10.1.30.1

Le périmètre se limite **au laboratoire de l’auditeur** : ses six machines virtuelles. Sont **exclus** : les laboratoires des autres apprenants, l’infrastructure de la plateforme Hexceos (passerelle 10.10.0.1, adresses en .254 présentes sur chaque réseau, portail et consoles), et tout système sur Internet. Un élément de la plateforme découvert pendant l’audit peut être **documenté** comme constat, mais ne doit être ni balayé ni testé.

4. Actions autorisées et interdites

Autorisées : consultation des configurations (boîte blanche) ; découverte réseau et identification de services ; scans de vulnérabilités (Greenbone, nmap NSE de catégorie « safe » et « vuln ») ; tests de flux pour vérifier le cloisonnement ; analyse TLS et SSH (testssl.sh, ssh-audit) ; lecture des journaux.

Interdites : toute action destructrice ou de déni de service ; la modification de configuration pendant l’audit (sauf accord écrit) ; l’exploitation de vulnérabilités au-delà de la preuve de leur existence ; l’extraction de données hors du laboratoire ; toute action hors du périmètre défini au §3.

5. Calendrier et contacts

Fenêtre d'audit : séance du TP 8, horaires de la formation. Contact du commanditaire et en cas d'incident : le formateur, présent en salle. Tout effet de bord constaté (service indisponible, blocage) est signalé immédiatement.

6. Confidentialité et livrables

Les constats, preuves et le rapport sont confidentiels et remis au seul commanditaire. Livrable : `rapport-audit` (synthèse pour la direction, contexte et périmètre, constats cotés avec preuves, plan d'action priorisé, annexe méthode et outils).

7. Signatures

Commanditaire (formateur)	Auditeur (apprenant)
Date :	Date :
Signature :	Signature :